

Governance in Practice

WHY THIS MODULE MATTERS

This is the operational core of the course: the inventory, the risk tiers, the named owners, the checkpoints and the escalation route. None of it is complicated. Almost all of it is missing in organisations that have an AI policy.

6.1 Structure: Who Does What

Governance fails in two opposite ways. It is concentrated in one person who becomes a bottleneck and is eventually bypassed, or it is spread so widely that no individual owns any outcome. The workable arrangement sits between them.

The structure below scales down as well as up. In a large organisation these are committees; in a company of thirty they are three named people who also do other jobs. What matters is that each layer exists and that the names are written down.

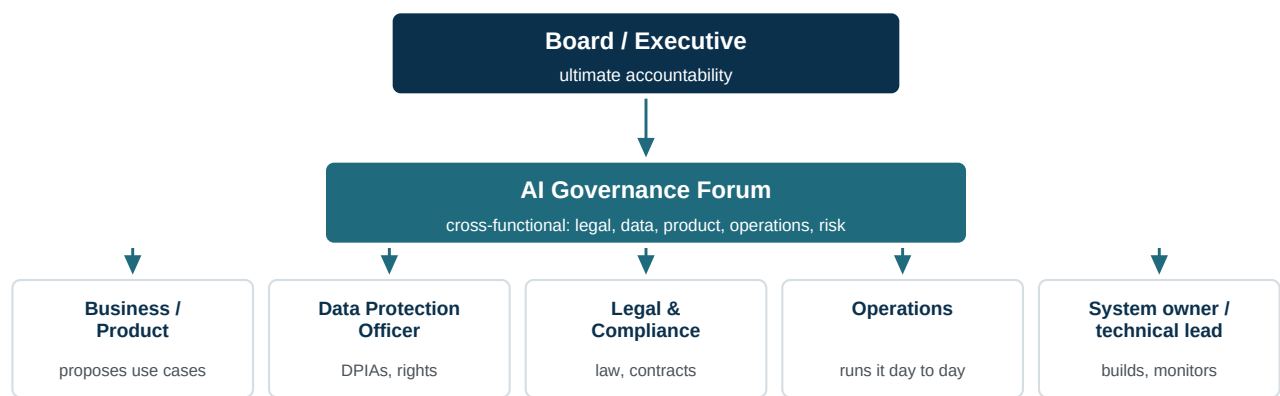


Figure 6.1 — A governance structure that distributes accountability across roles rather than concentrating it in one.

- **Board or executive** — sets risk appetite, receives regular reporting, and is accountable for the organisation's overall position. Cannot delegate this.
- **Governance forum** — reviews and approves systems above a defined risk threshold, with authority to refuse. A forum that has never refused anything is a rubber stamp.
- **System owner** — a named individual accountable for one specific system throughout its life, including the decision to withdraw it.
- **Data protection function** — the DPO where one is required, advising on lawful basis and DPIAs, with a route to report independently.
- **Delivery teams** — engineering, product and operations, who implement controls and raise concerns.
- **Assurance** — internal audit or an equivalent independent check that the process is actually being followed.

6.2 The Inventory

You cannot govern what you have not listed. The AI inventory is the foundational artefact and it is genuinely simple: one row per system, recording what it does, who owns it, what data it uses, whether it makes or informs decisions about people, what its lawful basis is, and when it was last reviewed.

The obstacle is never the format. It is discovery — finding the AI features embedded inside tools nobody thinks of as AI systems: the scoring inside a payments platform, the ranking inside a recruitment portal, the

summarisation inside a helpdesk product, the assistant inside an office suite. The most productive question to ask departments is not "what AI do you use?" but "what does software decide for you?"

6.3 Risk Tiering

Once the inventory exists, systems must be sorted, because uniform scrutiny means inadequate scrutiny of the systems that matter. A four-tier ladder is sufficient for most organisations.

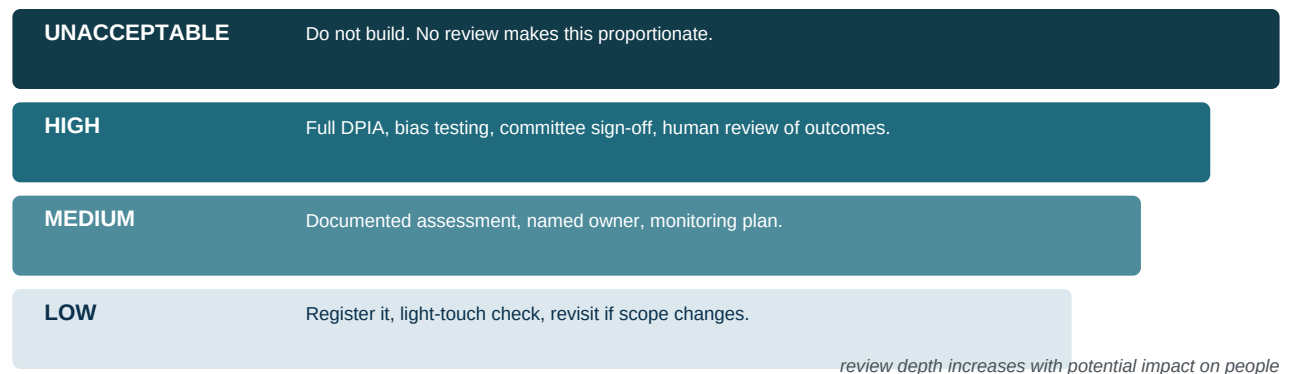


Figure 6.2 — A four-tier risk ladder; review depth rises with potential impact on people.

The tier should be driven by consequence to the affected person, and by whether a human meaningfully stands between the output and the outcome. A system recommending stock levels and a system recommending which customers to refuse service to may use identical technology and belong in entirely different tiers.

6.4 Clear Roles for Each Activity

Even with an owner named, specific activities need specific assignments — otherwise the owner is nominally accountable for work nobody has actually been asked to do. A RACI matrix is the conventional tool and takes about an hour to complete per system.

ACTIVITY	Product	DPO	Legal	Model owner	Committee
Propose a use case	R	C	C	C	A
Run the DPIA	C	R	C	C	A
Approve green claims	C	I	R	I	A
Bias testing	C	C	I	R	A
Sign off high-risk launch	I	C	C	C	R

R = Responsible A = Accountable C = Consulted I = Informed

Figure 6.3 — A RACI matrix clarifying who is Responsible, Accountable, Consulted and Informed for each governance activity.

6.5 Checkpoints, Not a Final Gate

The most common structural mistake is placing governance at the end, as a review immediately before launch. By that point the design is fixed, the budget is spent and the date is announced, so the review can realistically only approve. Governance placed early is cheap; governance placed late is theatre.

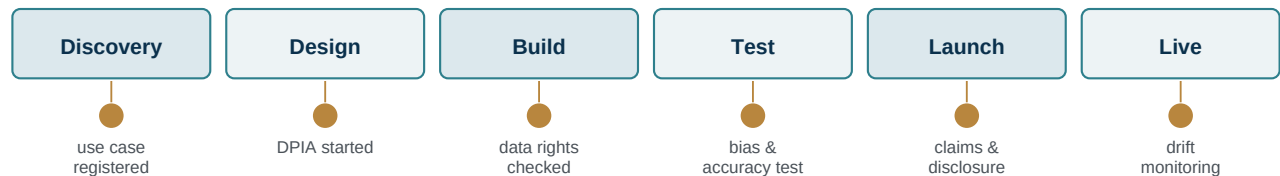


Figure 6.4 — Governance checkpoints distributed across delivery rather than concentrated in a single pre-launch review.

IN PRACTICE

A useful rule of thumb: the first checkpoint should occur before anyone writes code or signs a contract, and it should ask one question — what decision will this system make about people, and would we be comfortable explaining it publicly? Projects that cannot answer that at the outset rarely answer it better later.

6.6 Monitoring and Escalation

Deployment is the beginning of governance, not the end of it. Monitoring means measuring the system against real-world outcomes — not its own confidence scores — broken down by the groups it affects, on a defined cadence, against thresholds agreed in advance. Thresholds set in advance are the mechanism that converts a judgement call under pressure into a pre-agreed action.

Escalation must have a route that works when the person who notices is junior and the system is important. Most AI incidents are visible to a front-line worker weeks before they are visible to an executive, and the determining factor is whether raising it is straightforward and safe.

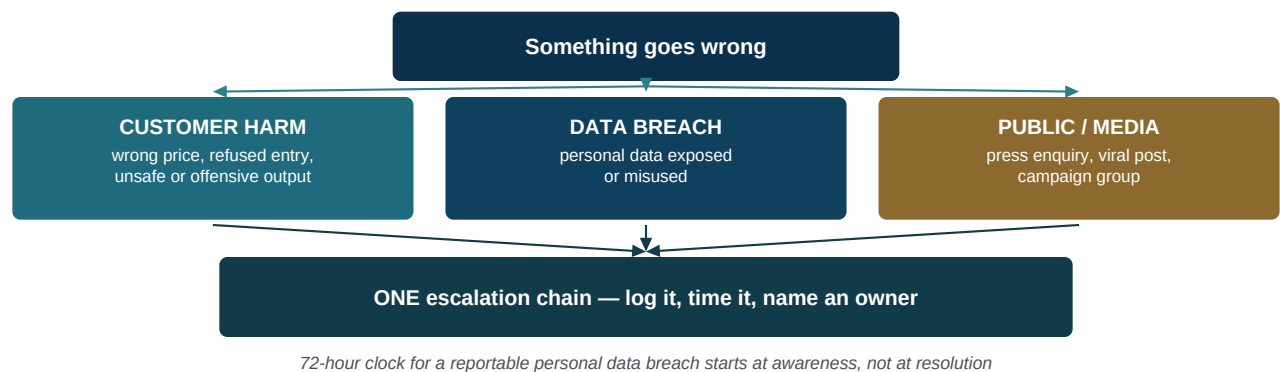


Figure 6.5 — An incident response workflow, connecting technical and communications branches back to the same escalation and logging step.

One detail with legal weight: if an incident involves personal data and presents a risk to individuals, the ICO must be notified within 72 hours of the organisation becoming aware. The clock starts at awareness, not at confirmation, and not when the investigation concludes.

6.7 Knowing Where You Stand

Maturity models are useful mainly for honesty. Most organisations beginning this work sit at level one or two, and the value of saying so plainly is that it makes the next step obvious rather than aspirational.

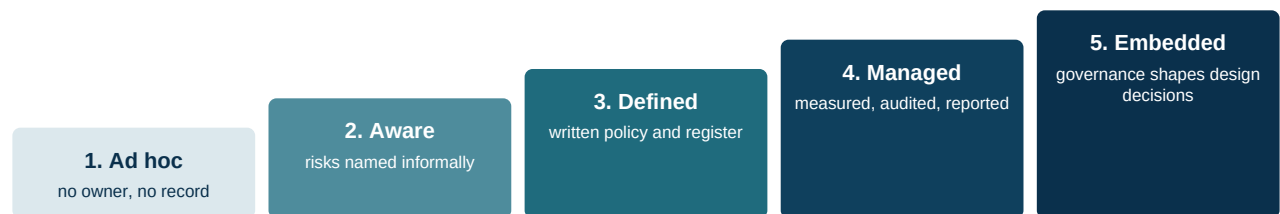


Figure 6.6 — A five-level governance maturity model.

TRY THIS — BUILD THE FIRST TEN ROWS

Draft an inventory of ten AI systems in your organisation. For each, record: what it does, who owns it by name, what data it uses, whether it decides or informs, and what would happen if it were switched off tomorrow.

Then assign each a tier using Figure 6.2. You will almost certainly find at least one system in a higher tier than anyone had assumed, and at least one with no owner at all. Those two are your starting points.

TRY THIS — CAPSTONE: ONE SYSTEM, ONE PAGE

This exercise draws on all six modules and is the practical requirement for certification. Choose one real AI system you have direct contact with. In no more than one page, set out: what it does and who it affects; which of the six principles from Module 2 it is weakest on; its risk tier under Figure 6.2 and your reasoning; what personal data it uses and on what lawful basis; who is accountable by name; what the first observable sign of failure would be and who would see it; and one specific change you would make.

Any section you cannot complete is itself the finding — record it as a gap rather than leaving it blank. Take the finished page to whoever owns the system. Done once and acted on, this is worth more than a policy document nobody reads.

KEY TAKEAWAYS

- Accountability should be distributed across board, forum, named system owner, data protection function, delivery and assurance — not concentrated or diffused.
- The inventory comes first; the hard part is discovering AI embedded in tools nobody classifies as AI.
- Tier systems by consequence to the affected person and by whether a human meaningfully stands between output and outcome.
- Governance checkpoints must start before code or contract; a single pre-launch review can only ever approve.
- Monitor against real outcomes broken down by group, with thresholds agreed in advance, and ensure escalation works from the bottom of the organisation upward.
- Personal data breaches presenting a risk to individuals must reach the ICO within 72 hours of awareness.

FURTHER READING

- NIST — AI Risk Management Framework (AI RMF 1.0)
- ISO/IEC 42001 — AI management systems standard
- ICO — Accountability Framework, ico.org.uk

CHECK-IN QUIZ

1. A governance review is scheduled for the week before launch, after the budget is spent and the date is announced. The predictable consequence is that:

- A. The review can realistically only approve
- B. The review will be thorough because the system is complete
- C. The review will be deferred until after launch
- D. The vendor will be asked to repeat its testing

CHECK-IN QUIZ

2. A monthly report shows the model's average confidence score is stable at 94%. As evidence that the system is working, this is:

- A. Sufficient, since confidence tracks accuracy
- B. Sufficient if the vendor confirms the figure
- C. Only relevant for high-tier systems
- D. Inadequate — performance must be measured against real outcomes, broken down by group

3. Two teams use the same model. One ranks internal maintenance jobs; the other ranks families for a welfare intervention. Correct tiering places them:

- A. In the same tier, because the model is identical
- B. In different tiers, because consequence to the affected person differs
- C. Both in the highest tier, as a precaution
- D. Outside tiering until an incident occurs

4. An adviser spots a pattern of wrong outcomes but does not report it, saying it "would not go down well". This indicates a failure of:

- A. The escalation route
- B. Model monitoring
- C. Vendor management
- D. Data minimisation

5. An organisation honestly assesses itself at level two of a five-level maturity model. The main value of doing so is that:

- A. It satisfies the ISO/IEC 42001 requirement for self-assessment
- B. It can be reported to the ICO as evidence of compliance
- C. It justifies deferring governance work until resources allow
- D. It makes the realistic next step obvious rather than aspirational